Compliance Annotation

MedSync Health Technologies, Inc.

Framework: HIPAA + SOC 2 | Compliance Level: Highly Compliant

---

Finding 1: [COMPLIANT] HIPAA: NPP Content & Mandatory Header (45 CFR 164.520) The notice includes the mandatory verbatim header regarding the description of uses and disclosures and how to gain access . It comprehensively covers the entity's legal duties to maintain privacy and provide breach notifications. **References:** 45 CFR 164.520(b)(1)(i)

Finding 2: [COMPLIANT] HIPAA: TPO & Minimum Necessary Standards (45 CFR 164.502) Uses for Treatment, Payment, and Healthcare Operations (TPO) are described with high specificity, including care coordination, prior authorization, and provider credentialing . Crucially, MedSync explicitly commits to applying the "minimum necessary" standard to all operational disclosures. **References:** 45 CFR 164.502(b), 164.520(b)(1)(ii)

Finding 3: [COMPLIANT] HIPAA: Detailed Patient Rights & Regulatory Timelines (45 CFR 164.524-528) All eight mandatory HIPAA rights are enumerated, including the self-pay restriction and the right to an accounting of disclosures . The policy explicitly states the correct 30-day window for access and 60-day window for amendment requests. **References:** 45 CFR 164.520(b)(1)(iv), 45 CFR 164.522, 164.524, 164.528

Finding 4: [COMPLIANT] HIPAA: Business Associate Oversight & Breach Notification (45 CFR 164.404, 164.504) MedSync requires all Business Associates (BAs) to execute a BAA. Notably, it enforces a 30-day breach notification window for BAs , which is stricter than the 60-day individual notification window it maintains for its own direct services. **References:** 45 CFR 164.404, 164.504(e)

Finding 5: [COMPLIANT] SOC 2: Security Governance & Oversight (CC1) The Information Security program is led by a CISO who reports to the CEO and Board. A cross-functional Security and Compliance Steering Committee meets quarterly to review incident trends and regulatory status. **References:** SOC 2 CC1.1, CC1.2, CC1.5

Finding 6: [COMPLIANT] SOC 2: Integrated Risk Management & HIPAA SRA (CC3, 45 CFR 164.308) MedSync performs an integrated annual risk assessment that concurrently satisfies SOC 2 CC3 and the HIPAA Security Rule requirement for a Security Risk Analysis (SRA). Risk responses are tracked in a GRC platform and require CISO and Legal sign-off . **References:** SOC 2 CC3, 45 CFR 164.308(a)(1)

Finding 7: [COMPLIANT] SOC 2: Logical Access & Multi-Factor Authentication (CC6, 45 CFR 164.312) MFA via Duo is mandatory for all users. Access is provisioned via formal workflows and requires additional Privacy Officer approval for PHI access. Access revocation is

mandated as "same-day" upon termination, exceeding common industry standards. **References:** SOC 2 CC6.1, 45 CFR 164.312(a)(1)

Finding 8: [COMPLIANT] SOC 2: Encryption & FIPS 140-2 Compliance (CC6, C1, 45 CFR 164.312) At-rest data is encrypted using AES-256 with FIPS 140-2 validated modules. All transmissions use TLS 1.3/1.2, and telehealth sessions are protected by end-to-end encryption . **References:** SOC 2 CC6.1, C1.1, 45 CFR 164.312(a)(2)(iv)

Finding 9: [COMPLIANT] SOC 2: System Monitoring & 24/7 SOC Operations (CC7) The entity operates a 24/7 Security Operations Centre (SOC) using advanced endpoint detection and infrastructure monitoring. Logs for PHI access and administrative actions are retained for 12 months in immutable storage. **References:** SOC 2 CC7.2, 45 CFR 164.312(b)

Finding 10: [COMPLIANT] SOC 2: Change Management & CI/CD Integrity (CC8) A formal change management process involves Jira tracking, GitHub peer reviews, and automated CI/CD testing gates . Emergency changes require a mandatory post-implementation review within 48 hours. **References:** SOC 2 CC8.1

Finding 11: [COMPLIANT] SOC 2: Availability & Contingency Planning (A1, 45 CFR 164.308) Multi-region deployment across AWS provides automated failover. Disaster recovery plans—tested quarterly—maintain aggressive RPO/RTO targets of 4 hours, which significantly mitigates availability risks . **References:** SOC 2 A1.2, 45 CFR 164.308(a)(7)

Finding 12: [COMPLIANT] SOC 2: Vendor Risk Management & SOC 2 Reviews (CC9) MedSync conducts pre-engagement risk assessments, including mandatory reviews of vendor SOC 2 Type II reports and HIPAA compliance programs . Contracts include 24-hour breach notification obligations and right-to-audit provisions. **References:** SOC 2 CC9.2

Finding 13: [COMPLIANT] SOC 2: Workforce Training & Phishing Simulations (CC1.4) Annual HIPAA and SOC 2 training is mandatory for all staff . This is supplemented by quarterly phishing simulations and specialized secure coding training for developers (OWASP). **References:** SOC 2 CC1.4, 45 CFR 164.308(a)(5)